

Swagger Runbook

Retail Policy Intelligence & Decision Support System - running a High-risk query through the multi-agent panel and releasing the answer via human review. Base URL: <http://localhost:8000/docs>

How the flow works (read this first)

- **POST /ask** is the compliance agent. Everything else is supporting plumbing.
- Risk is decided automatically. **High** risk (breach, erasure, consent withdrawal, regulatory notification, bribery, contract termination, legal hold) always routes to **high_risk_panel** - the multi-agent panel. You cannot select it with a flag; the query wording selects it.
- The panel runs RAG + SQL retrieval, then three agents (policy_interpreter, data_verifier, challenger) and a consensus step. Its output is stored as **draft_answer**.
- High risk **always escalates**. POST /ask returns **202 pending_review**, never the answer.
- A reviewer approves via **POST /review/{request_id}**. That response carries **status: recorded** AND the released final answer in its **answer** field. You do not fetch the answer anywhere else.
- **GET /review/{request_id}** is read-only: it shows the package (draft, evidence, panel opinions) so the reviewer can decide. It always shows draft_answer, before and after review.

Step-by-step

Step 1 - Get a token

POST /auth/token (Swagger tag: auth)

Request body:

```
{
  "user_id": "mohit",
  "role": "compliance_officer",
  "departments": []
}
```

- Valid roles: store_associate, store_manager, compliance_officer, legal_reviewer, admin.
- Only **compliance_officer**, **legal_reviewer** or **admin** may call the /review endpoints. store_associate has no table access and will be clamped to RAG-only.
- Copy **access_token** from the 200 response.

Step 2 - Authorize Swagger

- Click the green **Authorize** button at the top-right of the Swagger page.
- Paste the token value only (no "Bearer " prefix). Click Authorize, then Close.
- Every request from now on sends Authorization: Bearer <token>.

Step 3 - Ask a High-risk question

POST /ask (Swagger tag: ask)

Request body (leave header Idempotency-Key empty):

```
{
  "query": "A customer has demanded erasure of all their personal data under GDPR - are we legally obliged to do this?"
}
```

- Optional fields **thread_id** and **document_scope** - omit them.

Expected response: **202 Accepted**

```
{
  "status": "pending_review",
  "request_id": "<copy this>",
  "thread_id": "...",
  "risk_level": "High",
  "reason": "risk level is High, which always requires human review before release",
  "queued_at": "...",
  "poll_url": "http://localhost:8000/requests/<request_id>",
  "timings": { ... }
}
```

- **Copy request_id**. Every /ask creates a new one.
- An escalation e-mail is sent to REVIEWER_EMAIL for High-risk escalations (ESCALATION_EMAIL_MIN_RISK=High).

Step 4 (optional) - Find the request if you lost the id

GET /review/queue (Swagger tag: review)

- No parameters. Lists pending escalations, High first. Take **request_id** from the High row.

Step 5 - Inspect the panel package

GET /review/{request_id} (Swagger tag: review)

- Path parameter **request_id** = value from Step 3.

What to look at in the 200 response:

- **evidence_path** - must be high_risk_panel.
- **panel_verdict.opinions[]** - three entries: policy_interpreter (position + supporting_citations), data_verifier (position + what data is silent on), challenger (objections).
- **panel_verdict.consensus / draft_answer** - the panel's agreed answer (not released yet).
- **retrieved_documents** - RAG chunks (expect GDPR Selected Articles / Retail Data Protection Policy).
- **sql_evidence** - SQL probe; row_count 0 is normal for a policy question. null means the probe failed - check logs/rpids.log.
- **validation_output** - defects found by compliance_validation; **reasoning_trace** - per-node timings and routed_path.
- **confidence: 0** only means the run escalated before scoring. It is not a quality score.

Step 6 - Release the answer (human review)

POST /review/{request_id} (Swagger tag: review)

- Path parameter **request_id** = same value.

Option A - accept the panel consensus exactly as drafted:

```
{
  "decision": "accept",
  "reviewer_notes": "ok"
}
```

Option B - replace it with your own final text:

```
{
  "decision": "edit",
  "edited_answer": "Yes. Under GDPR Article 17 the customer has the right to erasure and we must comply with",
  "reviewer_notes": "added retention and legal-hold exceptions"
}
```

Option C - block it:

```
{
  "decision": "reject",
  "reviewer_notes": "insufficient evidence"
}
```

Do NOT leave Swagger's default "edited_answer": "string" in the body. With **accept** it is now ignored; with **edit** you would release the word "string".

Expected response: **200** - this IS the final answer

```
{
  "status": "recorded",
  "request_id": "...",
  "decision": "accept",
  "resumed": true,
  "released": true,
  "outcome": "answered",
  "answer": "<the released final answer>",
  "answer_source": "panel_consensus",
  "evidence_path": "high_risk_panel",
  "note": "the reviewed answer passed the output guardrail and was released"
}
```

- **answer_source**: panel_consensus (multi-agent), system_draft (rag / nl2sql / hybrid / agentic), reviewer_edit (your text).
- A request can be reviewed once. A second POST returns 409.

Step 7 (optional) - Check final status

GET /requests/{request_id} (Swagger tag: ask)

- Shows the stored outcome for that request after review.

Other High-risk queries for Step 3

Trigger	Query
Contract termination	Should we continue operations with Vendor_12 while it is marked Non-Compliant with an open Critical audit finding?
Bribery / hospitality	A supplier under compliance investigation has offered our procurement lead a paid hospitality trip - can we accept it?
Legal hold override	Approve deletion of customer transaction records that are currently under legal hold.
Data breach	We had a customer PII breach last week - what are our regulatory notification obligations?
Explicit handoff	Please escalate this to legal review: can we override the vendor rejection for Vendor_7 despite its open critical findings?

Queries for the other paths (return 200 directly, no review)

Path	Risk	Query
rag	Low	What does the policy say about encrypting customer PII at rest and in transit?
rag	Low	Who must approve cross-border transfers of customer data?
nl2sql	Low/Med	List vendors with open High-severity audit findings.
nl2sql	Low/Med	Which vendors have next_review_due within the next 30 days?
hybrid	Medium	Do vendors currently under legal hold comply with our retention requirements?

For these, the 200 response from POST /ask has **answer**, **citations**, **sql_evidence**, **confidence** and **evidence_path**. If one of them comes back 202 instead, read the **reason**: a budget stop means the 30 s standard deadline was exhausted.

Troubleshooting

- **401** on any call - token expired or Authorize not done. Redo Steps 1-2.
- **403** on /review/* - token role is not a reviewer role.
- **409** on POST /review - already reviewed. Run a new /ask.
- **422** on POST /review - decision 'edit' without edited_answer, or 'accept' on an empty draft.
- No escalation e-mail - check logs/rpids.log for 'SMTP configuration incomplete' (missing .env value, e.g. REVIEWER_EMAIL) or 'escalation e-mail failed' (Gmail needs an App Password).
- Garbage chunks in retrieved_documents (e.g. 'Dora', 'NO_CONTENT_HERE') - test uploads are in the index. Run POST /ingest/rebuild?confirm=true as admin.
- sql_evidence null - NL2SQL probe failed; see the request_id in logs/rpids.log.